# Investigación de casos reales de vulnerabilidades

*Unidad 3 — Actividad de investigación teórica*

Nombre: Benjamín Ibáñez Fecha: 30 de octubre de 2026

Este documento reúne tres casos reales y documentados públicamente: uno de inyección SQL, uno de XSS y uno de control de acceso incorrecto. La investigación es teórica, es decir, se basa solo en fuentes públicas y no se hicieron pruebas sobre ningún sistema. En cada ficha se separa lo que la fuente confirma de lo que es solo un riesgo posible.

## Investigación

## Caso 1 — Inyección SQL: MOVEit Transfer (CVE-2023-34362)

**1. Identificación:** Progress Software, producto MOVEit Transfer (un sistema para transferir archivos de forma segura que usaban empresas, universidades y organismos públicos). La empresa publicó el aviso el 31 de mayo de 2023; según el aviso conjunto de FBI y CISA, los ataques comenzaron el 27 de mayo de 2023.

**2. Vulnerabilidad:** Inyección SQL, CVE-2023-34362. Es una vulnerabilidad crítica de tipo “zero-day”: no se conocía cuando empezaron a explotarla.

**3. Funcionamiento:** La aplicación web de MOVEit armaba sus consultas a la base de datos pegando datos que venían del usuario, en vez de tratarlos como simples valores. Eso permitía “colar” instrucciones SQL y hacer que la base ejecutara órdenes que el atacante no debía poder dar. Con esa entrada, el grupo atacante instaló un web shell llamado LEMURLOOT, que sirve para ejecutar comandos en el servidor y sacar información de la base de datos. La falla afectaba directamente a la capa web y a la base de datos que hay detrás.

**4. Consecuencias:** Confirmado: hubo robo de datos desde las bases de MOVEit en muchas organizaciones, y el grupo Cl0p (también conocido como TA505) usó lo robado para extorsionar a los afectados. Según el conteo público de Emsisoft (actualizado a junio de 2024), fueron 2.773 organizaciones y 95.788.491 personas afectadas; es una estimación acumulada de notificaciones públicas, no una cifra oficial única. Riesgo posible: los datos robados (nombres, documentos, datos financieros) pueden reutilizarse en fraudes y suplantaciones durante años.

**5. Prevención:** Usar consultas parametrizadas (prepared statements) o un ORM, de modo que el dato nunca se pegue dentro del texto de la consulta; validar las entradas; dar a la cuenta de base de datos solo los permisos que necesita; y monitorear la aparición de web shells en servidores expuestos a Internet. La razón es simple: si el dato viaja separado de la estructura de la consulta, no puede cambiar lo que la base ejecuta.

**6. Fuente:** FBI y CISA, “#StopRansomware: CL0P Ransomware Gang Exploits CVE-2023-34362 MOVEit Vulnerability” (AA23-158A), 7 de junio de 2023, https://www.cisa.gov/news-

events/cybersecurity-advisories/aa23-158a. Cifras: Emsisoft, “Unpacking the MOVEit Breach: Statistics and Analysis”, 18 de julio de 2023 (actualizado al 28 de junio de 2024), https://www.emsisoft.com/en/blog/44123/unpacking-the-moveit-breach-statistics-and-analysis/. Consultadas el 30 de octubre de 2026.

## Caso 2 — Cross-Site Scripting (XSS): cuentas de Epic Games / Fortnite (2019)

**1. Identificación:** Epic Games, específicamente la plataforma de cuentas y algunos subdominios de Fortnite. El caso se conoció el 16 de enero de 2019, cuando Check Point Research publicó la investigación después de avisar a la empresa.

**2. Vulnerabilidad:** Cross-Site Scripting (XSS), en dos partes: un subdominio antiguo que reflejaba un parámetro sin escapar y un parámetro de redirección del inicio de sesión (SSO) que aceptaba dominios manipulados. No tiene CVE, porque se divulgó de forma coordinada y se corrigió antes de hacerse pública: es una vulnerabilidad publicada, no un incidente de robo confirmado.

**3. Funcionamiento:** Una página del subdominio ut2004stats.epicgames.com mostraba el nombre del mapa que venía en la dirección (URL) sin limpiarlo. Si en ese parámetro se escribía código, el navegador lo ejecutaba como si fuera parte del sitio de Epic. Como el inicio de sesión usaba un parámetro redirectUrl que no validaba bien el destino, ese código podía llevarse el token de sesión de la víctima hacia un dominio del atacante. Así, la persona solo tenía que hacer clic en un enlace para que su cuenta quedara en manos de otro, sin escribir su contraseña.

**4. Consecuencias:** Confirmado: la falla existía y Epic la corrigió tras el aviso de los investigadores; no hay evidencia pública de que se haya explotado antes de la corrección. Riesgo posible: tomar el control de cualquier cuenta, ver datos personales, comprar V-Bucks con la cuenta ajena y escuchar o grabar el chat de voz. La fuente plantea el riesgo, pero no confirma robos reales.

**5. Prevención:** Escapar la salida según el contexto donde se muestra el dato (HTML, atributo, JavaScript), sanitizar el HTML enriquecido, marcar las cookies de sesión como HttpOnly para que el script no las lea, aplicar una política de seguridad de contenido (CSP) y validar el parámetro de redirección contra una lista blanca de dominios propios. Cada medida ataca un eslabón distinto de la misma cadena: que el código no se ejecute, que no pueda leer la sesión y que no pueda llevarse a la víctima a otro sitio.

**6. Fuente:** Check Point Research, “Hacking Fortnite Accounts”, 16 de enero de 2019, https://research.checkpoint.com/2019/hacking-fortnite/. Consultado el 30 de octubre de 2026.

## Caso 3 — Control de acceso incorrecto: First American Financial (2019)

**1. Identificación:** First American Financial Corp., compañía de seguros de título inmobiliario de Estados Unidos (puesto 500 de Fortune), a través de su sitio firstam.com. Lo detectó el

desarrollador Ben Shoval y lo publicó Brian Krebs (KrebsOnSecurity) el 24 de mayo de 2019; los documentos expuestos iban desde 2003 hasta 2019.

**2. Vulnerabilidad:** Control de acceso incorrecto, en su forma clásica de IDOR (referencia directa insegura a objetos). No tiene CVE: fue un defecto de diseño del sitio, no una falla de un producto con aviso público.

**3. Funcionamiento:** Cada documento tenía un enlace con un número correlativo de nueve dígitos. El sitio entregaba el archivo a cualquiera que tuviera el enlace, sin pedir inicio de sesión ni comprobar si esa persona tenía derecho a verlo. Bastaba cambiar un dígito del número para abrir el documento de otra persona, de otra fecha y de otra operación inmobiliaria. El sistema confiaba en que el enlace era "difícil de adivinar", pero los números eran consecutivos.

**4. Consecuencias:** Confirmado: cerca de 885 millones de archivos quedaron accesibles sin autenticación, entre ellos escrituras, estados de cuenta bancarios, números de seguridad social, licencias de conducir y recibos de transferencias. La empresa cerró el acceso cuando fue notificada. No se confirmó públicamente que alguien los haya descargado de forma masiva; ese es el riesgo posible (fraude de identidad y suplantación con datos reales de personas).

**5. Prevención:** Verificar los permisos en el servidor en cada solicitud, no solo esconder los enlaces; usar identificadores no adivinables (UUID) en lugar de números correlativos; comprobar que el recurso pertenezca al usuario o a la organización que lo pide; y probar el acceso con dos usuarios distintos para confirmar que uno no ve lo del otro. La idea de fondo es que la seguridad no puede depender de que nadie adivine una dirección.

**6. Fuente:** Brian Krebs, "First American Financial Corp. Leaked Hundreds of Millions of Title Insurance Records", KrebsOnSecurity, 24 de mayo de 2019, https://krebsonsecurity.com/2019/05/first-american-financial-corp-leaked-hundreds-of-millions-of-title-insurance-records/. Consultado el 30 de octubre de 2026.

## Para cerrar: comparación de los tres casos

Los tres casos parten de lo mismo —el sistema confía en un dato que viene de afuera—, pero el daño ocurre en lugares distintos. En MOVEit el problema está en la base de datos: el dato del usuario se mezcla con la consulta y termina ejecutándose como instrucción. En Epic Games el daño ocurre en el navegador de otra persona: el sitio muestra un dato sin limpiarlo y el código se ejecuta con los permisos de la víctima. En First American no se rompe nada técnico: el sistema simplemente no pregunta si quien pide el documento tiene permiso, y el dato afectado son los documentos de terceros. Dicho de otro modo, la inyección SQL y el XSS atacan la forma en que el sistema procesa la información, y el control de acceso incorrecto ataca la forma en que el sistema decide quién puede verla.

Lo que un equipo de calidad podría observar es parecido en los tres casos: parámetros que aceptan caracteres o valores inesperados, mensajes de error que muestran detalles internos, enlaces con

identificadores correlativos, y respuestas exitosas (200) a recursos que pertenecen a otra persona. La forma de comunicarlo también es común: reproducir el caso con datos de prueba, indicar qué información o componente se ve afectado, estimar el impacto (datos personales, cuentas, documentos) y proponer la corrección, sin difundir datos reales de usuarios. La lección que queda es que casi ninguna de estas fallas se ve “a simple vista” en la pantalla: aparecen al probar lo que pasa cuando el usuario hace algo que el desarrollador no esperaba.

## Fuentes utilizadas


CISA y FBI. “#StopRansomware: CL0P Ransomware Gang Exploits CVE-2023-34362 MOVEit Vulnerability” (AA23-158A). 7 de junio de 2023. https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a

Emsisoft. “Unpacking the MOVEit Breach: Statistics and Analysis”. 18 de julio de 2023, actualizado al 28 de junio de 2024. https://www.emsisoft.com/en/blog/44123/unpacking-the-moveit-breach-statistics-and-analysis/

Check Point Research. “Hacking Fortnite Accounts”. 16 de enero de 2019. https://research.checkpoint.com/2019/hacking-fortnite/

Krebs, Brian. “First American Financial Corp. Leaked Hundreds of Millions of Title Insurance Records”. KrebsOnSecurity, 24 de mayo de 2019. https://krebsonsecurity.com/2019/05/first-american-financial-corp-leaked-hundreds-of-millions-of-title-insurance-records/

Todas las fuentes fueron consultadas el 30 de octubre de 2026.